

暗号化基準

1. 文書管理

本文書は当行の情報システムにおける暗号化技術の選定基準および運用要件を定めるものである。文書番号は ISP-003

とし、情報セキュリティポリシー (ISP-001) の下位文書として位置づける。

本版は第2.3版 (2025年7月1日改定) であり、前版 (第2.2版、2024年12月1日) からの主な変更点は、耐量子暗号 (PQC) への移行準備方針の追加およびTLS

1.0/1.1の完全廃止に伴う設定更新である。FISC安全対策基準
技-25 (暗号化の実施) に準拠する。

本文書で定める暗号化基準は、データ保護ポリシー (ISP-004) で定めるデータ分類に基づき、機密度に応じた暗号化要件を規定する。暗号技術の選定にあたっては、CRYPTREC電子政府推奨暗号リストおよびNIST SP 800-131Aを参照する。

2. 暗号化アルゴリズム

共通鍵暗号方式には AES-256-GCM を標準として採用する。AES-128

は機密度「公開」のデータに限り使用を許可するが、新規システムでは AES-256

を原則とする。ブロック暗号の利用モードとして ECB モードの使用を禁止し、GCM または CBC モードを使用する。

公開鍵暗号方式には RSA-2048 を最低要件とし、2027年度以降の新規システムでは RSA-3072 以上または楕円曲線暗号 ECC P-256 (NIST P-256) 以上を採用する。RSA-1024 以下の鍵長は使用を禁止し、既存システムでの使用が確認された場合は即座に移行計画を策定する。デジタル署名にはRSA-PSS (SHA-256以上) またはECDSA (P-256以上) を使用する。

ハッシュ関数には SHA-256 以上を使用し、SHA-1 およびMD5

の使用は全面的に禁止する。パスワードハッシュには bcrypt (コストファクター12以上) または Argon2id を使用し、情報セキュリティポリシー (ISP-001) 第7章の要件を満たす。メッセージ認証コード (MAC) には HMAC-SHA-256 を使用する。

3. 鍵管理ライフサイクル

暗号鍵の管理は、生成・配布・保管・使用・ローテーション・廃棄のライフサイクル全体を通じて厳密に管理する。FISC安全対策基準

技-26 (暗号鍵の管理) に準拠した鍵管理プロセスを確立する。

暗号鍵の生成には FIPS 140-2 Level 3 以上の認定を受けた HSM (Hardware Security

Module) を使用する。鍵のエントロピーは NIST SP 800-90A に準拠した乱数生成器により確保する。マスター鍵の分割管理 (M-of-N方式、M=3、N=5) を実施し、単一の管理者による不正利用を防止する。

共通鍵のローテーション周期は原則として年1回とし、暗号化されたデータ量が10TB を超えた場合は追加のローテーションを実施する。公開鍵ペアのローテーション周期は2年とする。鍵の廃棄時にはHSM上での安全な消去を実施し、廃棄記録を10年間保存する。

4. 証明書管理

電子証明書の管理は、当行のPKI (Public Key Infrastructure) 基盤に基づき実施する。サーバ証明書は認定認証局 (CA) から取得し、自己署名証明書の本番環境での使用を禁止する。FISC安全対策基準 技-27 (電子証明書の管理) に準拠する。

証明書の有効期間は、サーバ証明書は最長1年、クライアント証明書は最長2年とする。証明書の有効期限の60日前から自動的にアラートを発信し、30日前までに更新を完了する。期限切れ証明書による障害を防止するため、証明書管理台帳を整備し月次で棚卸しを実施する。

証明書の失効処理にはOCSP (Online Certificate Status Protocol) およびCRLを使用する。秘密鍵の漏洩が疑われる場合は、当該証明書を直ちに失効させ、再発行する。ワイルドカード証明書の使用は原則として禁止し、やむを得ない場合は情報セキュリティ委員会の承認を要する。

5. HSM運用

暗号鍵の保護にはHSM (Hardware Security Module) を使用し、鍵がHSMの外部に平文で出力されることを禁止する。HSMはFIPS 140-2 Level 3以上またはCommon Criteria EAL4+以上の認定を受けた製品を使用する。

HSMの物理的設置場所はデータセンターのセキュリティゾーン内とし、入退室管理、監視カメラ、環境制御 (温度18-27℃、湿度40-60%) の設備基準を満たす場所に限定する。FISC安全対策基準 設-8 (コンピュータ室の物理セキュリティ) に準拠した設置環境を確保する。

HSMの冗長化構成 (Active-Standby) を維持し、単一障害点を排除する。HSMファームウェアの更新はベンダーのセキュリティアドバイザリに基づき、テスト環境での検証後に本番環境へ適用する。HSMの操作はPAMシステムを通じて実施し、全操作ログを記録する。HSMの廃棄時にはNI ST SP 800-88に準拠した媒体消去を実施する。

6. TLS設定基準

通信路の暗号化にはTLS 1.2以上を必須とし、TLS 1.3の採用を推奨する。TLS 1.0およびTLS 1.1は全システムで無効化を完了しており、使用を全面的に禁止する。SSL (全バージョン) の使用も同様に禁止する。

TLS 1.2で使用を許可する暗号スイートは以下に限定する。TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384、TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256、TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384。Perfect Forward Secrecy (PFS) を必須とし、ECDHE鍵交換を使用する。RSA鍵交換 (鍵輸送方式) は禁止する。

TLS 1.3で使用する暗号スイートはTLS_AES_256_GCM_SHA384およびTLS_CHACHA20_POLY1305_SHA256とする。HSTSヘッダを全Webアプリケーションで設定し、max-ageは最低3153600秒 (1年) とする。OCSP Staplingを有効化し、証明書検証の効率化とプライバシー保護を両立する。

7. 保存データ暗号化

機密度「機密」および「社外秘」に分類されるデータは、保存時（at rest）の暗号化を必須とする。データ分類の定義はデータ保護ポリシー（ISP-004）第2章に準拠する。FISC安全対策基準 技-28（保存データの暗号化）に基づき、適切な暗号化方式を適用する。

データベースの暗号化にはTDE（Transparent Data Encryption）またはカラムレベル暗号化を使用する。個人情報、口座情報、認証情報を含むカラムは必ずカラムレベル暗号化を適用する。暗号化キーはデータベースとは物理的に分離されたHSMで管理する。

ファイルストレージの暗号化には、サーバサイド暗号化（SSE）を適用する。クラウドストレージ（AWS S3等）を利用する場合は、CMK（Customer Managed Key）による暗号化を必須とし、クラウド事業者管理のキーのみに依存しない。バックアップデータも保存データと同等の暗号化要件を適用する。

8. 暗号監査

暗号化の実装状況および鍵管理の適切性について、年1回の定期監査を実施する。監査項目は、使用アルゴリズムの適切性、鍵長の充足性、ローテーションの実施状況、HSMの運用状況、証明書管理の状況を含む。

暗号技術の陳腐化リスクを継続的に評価し、CRYPTREC暗号リストの更新やNIST標準の改定に応じて本基準を見直す。耐量子暗号（PQC）への移行準備として、2026年度中にML-KEM（CRYSTALS-Kyber）およびML-DSA（CRYSTALS-Dilithium）の評価検証を完了する。

暗号監査の結果は情報セキュリティ委員会に報告し、是正が必要な事項については対応期限を設定して追跡管理する。外部の専門機関による暗号評価（ペネトレーションテストを含む）を2年に1回実施する。監査記録は7年間保存し、監査証跡の完全性を確保する。